

SECAUDIT 060 - skin-boundary migration integrity

SECURITY AUDIT / PUBLIC REMEDIATION RECORD

Field	Value
Audit ID	2026-10-05-060
Date	2026-10-05
Severity	MEDIUM security-program failure / HIGH operational impact. No active exploit or confidentiality breach was found. The security remediation caused widespread availability and integrity regressions because required behavior was removed without complete bounded replacements or parity gates.
Scope	Follow-up to SECAUDIT 059: schema-v2 public skin migration, strict controllers and view models, shared asset/component contracts, package policy, recovery changes through the local CMS 0.7.819D and GAME ON 0.1.24 candidates.
Method	Repository history and diff review; pre/post migration presentation and route inventories; strict render and route regressions; full PHP regression directory; fleet skin-security ratchet; review of representative live evidence supplied by the owner and earlier recovery records.
Status	OPEN - recovery candidate passes local security and regression gates; independent review, packaging, deployment, and live acceptance pending. This report does not close SECAUDIT 059's remaining fleet-wide parity work.
Reporter	Codex, commissioned by Sean. Owner supplied live reproduction evidence and impact record. Independent adversarial reviewer not yet assigned.
Related	SECAUDIT 059; OPAUDIT 020; pre-migration reference v0.7.772D; controller migration beginning at c9eb3a9e.
Disclosure	Private working report until fixes are deployed and reviewed. Publication is Sean's decision.

1. Summary

SECAUDIT 059 correctly found that signed PHP skins had excessive authority. Moving data access, request handling, writes, remote calls, and reusable behavior into the CMS was the right security decision. The execution of that decision was incomplete: old authority was removed before every legitimate result it produced had a bounded replacement. The security program therefore improved isolation while damaging availability and presentation integrity.

This matters to security because a remediation is not complete when it merely removes the dangerous mechanism. It must also preserve the authorized behavior through a safer path. A project that repeatedly restores missing behavior under emergency pressure is more likely to reintroduce authority, bypass gates, or normalize exceptions. The recovery itself therefore requires a security review, not only visual QA.

The current 0.7.819D / GAME ON 0.1.24 candidate retains the intended boundary. Validation, routing, data loading, repair decisions, and shared interactions remain in core or audited shared assets. GAME ON receives bounded display data and contains presentation-only template logic. TILEZ is not changed. The fleet security ratchet passes.

2. Findings

A. The security migration had no behavior-preservation gate (MEDIUM) - OPEN

Evidence: the constrained-controller migration began after v0.7.772D. Security and architecture tests passed while live skins subsequently lacked saved settings, backgrounds, navigation, controls, full feeds, search, image associations, routes, Blogrolls, static-page presentation, and footers. A read-only route audit later found 45 declared-route fallthroughs across 12 skins. A presentation diagnostic found 646 candidate pre-migration CSS hooks still referenced by current styles but no longer emitted.

Failure mode: authorized behavior silently disappears while the security gate stays green. The resulting emergency repairs create pressure to put logic back into templates, accept one-off exceptions, or weaken the scanner. Availability and content integrity are reduced, and confidence in the boundary becomes dependent on live users finding omissions.

Required fix: every security-boundary migration must have a two-sided gate: forbidden authority is absent, and required behavior is present through bounded contracts. The parity half must cover routes, settings, markup/components, registered assets, interaction behavior, responsive behavior, and saved non-default values.

B. Generic replacement layouts obscured capability-to-presentation dependencies (MEDIUM) - OPEN

Evidence: repository history contains mechanical replacement scripts for grid, public, and SMACKTALK families. Representative skins that previously had many route-specific templates and partials were reduced to a generic strict layout without a complete ledger of what each old path legitimately supplied.

Failure mode: security-sensitive removal and ordinary presentation redesign become mixed in one large mechanical change. Review can prove that SQL or request access vanished while missing the data attributes, component anchors, or bounded fields needed by a central engine.

Required fix: migration plans must map each old capability to one of three outcomes: forbidden and removed; legitimate and replaced by a named bounded contract; intentionally retired with owner approval. Bulk replacement is prohibited for independently packaged skins.

C. The recovery path was capable of drifting back toward template logic (LOW, caught) - CLOSED LOCALLY

Evidence: during the GAME ON recovery, a draft placed display-field validation and local decision variables in the skin template. The fleet security ratchet rejected the candidate before release. Validation was moved into `core/public-runtime.php`; the template now only escapes and presents the prepared values. The ratchet then passed.

Disposition: this did not ship. It is recorded because it demonstrates both the pressure created by incomplete contracts and the value of the fail-closed ratchet. The gate must remain mandatory in skin packaging, CMS release, and installation paths.

D. Release evidence did not distinguish security closure from visual parity (MEDIUM process) - OPEN

Evidence: multiple releases after the boundary conversion were described as restorations, yet further omissions were found only on live sites. Source assertions, asset registration, and generic rendering success were repeatedly treated as sufficient evidence of recovery.

Failure mode: a security fix can be marked complete while the product remains degraded, then subsequent fixes are made without the same deliberate threat review as the original migration. Release volume also makes it difficult to identify which package introduced or closed a specific boundary defect.

Required fix: release notes and gates must state separately: boundary controls verified; source behavior verified; packaged artifact verified; installed target verified; live user interaction verified. Only the last can close parity for that target.

3. Current candidate boundary review

Change	Authority owner	Data passed to skin	Security disposition
Clean route aliases and legacy redirects	CMS core	Final escaped URLs in navigation	Central validation and canonicalization; no request parsing added to skins.
SMACKTALK diary/image-archive split	CMS controller	Named response kind and bounded entries	Query and route authority remain central.
GRAMOFSMACK duplicate Archive suppression	CMS view-model/router	Navigation item omitted	No skin-side request or settings access.
GAME ON secondary-page background/count	CMS public runtime/repository	Bounded count and puzzle item array	Same approved view contract as landing; no PDO reaches the skin.
GAME ON page hero and Blogroll	CMS runtime/controller	Validated image presentation fields and grouped public links	Template performs presentation only; unsafe URL/content paths remain escaped or trusted centrally.
Standard footer	CMS component renderer	SnapTrustedHtml component token	Skin emits an already bounded component; no settings access.
Existing SMACKPRESS page repair	Authenticated API/tool	Existing page and media identifiers	Reuses imported media; refuses ambiguous changes; does not broaden public skin authority.

4. Tests and evidence

- Focused public-route, GAME ON, SMACKTALK-family, TILEZ-completion, and GRAM menu tests pass.
- Fleet skin-security ratchet passes after the template-side draft was corrected.
- Full PHP regression directory at this checkpoint: **162 passed, 0 failed**.
- `git diff --check` passes.
- CMS source is exactly 0.7.819D; GAME ON manifest is exactly 0.1.24; TILEZ remains 0.2.59.
- No claim is made yet for packaged-artifact or live behavior. Those gates remain open.

5. Six-chokepoint review

1. **Untrusted image ingress:** unchanged by this candidate. Page-image and imported-image references reuse existing sanitized/owned media paths. No decoder or upload authority is added to a skin.
2. **Config / manifest ingestion:** GAME ON stays schema-v2/security-policy 2. Its single declared template remains subject to the mandatory skin gate. No executable asset is added.
3. **JavaScript / IPC:** interaction stays in registered CMS assets. No skin JavaScript or desktop IPC is introduced.
4. **Update / restore channel:** release ordering remains an open operational control. The candidate must be packaged, signed, installed, and verified sequentially; no later version may be created first.
5. **Credentials / tokens:** no credential path changes and no credential material enters a

view model or skin package.

6. **Upload / SSRF:** no new remote fetch or upload surface. SMACKPRESS repair uses the existing authenticated API and refuses ambiguous media-count changes.

6. Closure requirements

- ☒ Current recovery diff passes the fleet security ratchet.
- ☒ Full local regression directory passes (162/162).
- ☒ Candidate versions are sequential: CMS 0.7.819D; GAME ON 0.1.24; TILEZ unchanged.
- ☐ Independent adversarial source review completed and disagreements recorded.
- ☐ Signed CMS 0.7.819D artifact inspected, installed, and verified on intended sites.
- ☐ Signed GAME ON 0.1.24 artifact inspected, installed, and live-verified.
- ☐ Live acceptance covers landing, photograph modal, Blogroll, About/static page, saved hero, footer, background, clean routes, and absence of duplicate Archive navigation.
- ☐ Remaining 059 fleet-parity candidates classified; no whole-fleet closure claimed from this bounded repair.
- ☐ OPAUDIT 020 updated with final deployment evidence and owner-approved close state.

7. Plain admission

The project enforced the new security boundary before it had fully designed or tested the replacement contracts. That made the code less powerful in skins but the product less reliable for users. Security work that breaks authorized behavior and then requires weeks of emergency restoration is not a successful rollout. The boundary should remain; the migration and release process must be corrected.